DECISION BRIEF

API integration audit

Evidence date: 18 October 2026 | Read-only application review

Review required before implementation

The current implementation has useful safeguards, but cannot yet be signed off as fully working for every activated merchant. Seven findings and the proposed tax design are presented for your review.

63 regression tests

654 assertions passed

10 audit tests

34 assertions; six gap observations

7 JavaScript tests

Offline recovery checks passed

What was verified

Isolated SQLite fixtures exercised active and pending merchants, owner/MFA credential controls, branch and tenant isolation, wallet shortfalls, duplicate retries, atomic batches, IP policy, and the tax calculator. Tests used synthetic records. No live account was activated, no sale was sent, and no application code was edited.

What remains unverified

Authenticated live intake for an activated merchant, MySQL concurrency under load, real ERP/POS adoption, browser storage recovery across devices, official BIR interoperability, and external webhook delivery. Issuance-authority checks were mocked only in controlled acceptance fixtures; a separate test confirmed the real gate blocks an active merchant without evidence.

Review package

Pages	Contents
2	Feature-by-feature outcome
3-4	Prioritized findings and evidence
5	Proposed VAT model and settings
6	Source capture, offline recovery and authorization
7	Implementation and acceptance plan
8	Official sources and audit boundaries

AUDIT RESULT

Feature readiness after activation

Review edition | 18 October 2026

Feature	Observed result	Assessment
Merchant activation	Pending submissions and new credential creation return 403. Active status unlocks the next checks.	Pass / conditional
Key lifecycle	Owner and fresh MFA; hash storage; one-time reveal; expiry, revocation and IP restrictions. Audit-failure atomicity gap remains.	Partial - A4
Single event / batch	Durable acceptance, same-source replay, conflict checks and batch rollback pass under fixtures.	Pass with gates
Wallet	402 blocks new eligible financial writes. Exact retry is free. Fee threshold and batch funding tested.	Pass in isolation
Tenant / branch access	Foreign merchant and branch reads denied. Same-branch sandbox key can read a live intake result.	Gap - A3
VAT and document types	Mixed 12% / exempt / zero-rated arithmetic reconciles. Registration-to-document rules are incomplete.	Gap - A1
Customer / CWT fields	Name and TIN accepted; buyer address and supplied withholding are discarded by validation.	Gap - A2
Testing Tools	Synthetic contract/maths only; seller registration inferred from header. No full staged API environment.	Partial - A6
Manual Retry	Encrypted source queue, matched acknowledgements and branch-specific replay pass JS checks.	Pass / field QA due
Webhooks / BIR	Callbacks remain platform-paused; BIR acceptance is explicitly not verified. Polling available.	Unavailable by design
Connection guide	Current page downloads .txt. This review includes a detailed PDF; wiring is proposed.	Gap - A7

A passing test proves the exercised behavior only. Reproduction tests intentionally assert existing faulty behavior to document a gap; they are not approval of that behavior.

FINDINGS / PRIORITY 1

Tax and data integrity gaps

Review edition | 18 October 2026

A1 - High | Registration, line tax and invoice family can disagree

Reproduced: a VAT seller can calculate and resolve a non_vat_invoice; a Non-VAT seller with vat_exempt lines resolves to vat_exempt_invoice. non_vat and vat_exempt both accumulate into vat_exempt_sales. There is no separate SSPT subtotal.

Proposed: use the reviewed seller registration as authoritative; validate every line and select the legal invoice family from that registration plus line treatments. Preserve separate Non-VAT SSPT and exempt categories where applicable. Never use a per-key toggle to rewrite registration.

A2 - High | Buyer address and withholding can disappear

Reproduced: customer_address, withholding_tax and tax_basis_reference supplied to version 1 are removed by validated(). The calculator is called with withholding zero; total_due equals gross_amount. A payload differing only in these discarded fields has the same canonical hash.

Proposed: a reviewed versioned schema must preserve buyer details, CWT amount/basis, invoice total and cash amount due separately. Reject unsupported financial fields instead of silently treating the document as complete. Preserve the original source snapshot and its hash.

Regulatory basis

VAT mixed invoices need separate VATable, VAT, exempt and zero-rated totals [S1-S2]. The official B5 sample is a Non-VAT mixed invoice, with SSPT and exempt sales [S3]. RR 6-2026 adds separately shown applicable CWT [S4].

Implementation evidence

`app/Services/IntegrationContract.php`
rules(), calculateDocument(), resolveDocument()
`app/Services/InvoiceCalculator.php`
Tax validation and shared non_vat / vat_exempt aggregation
`app/Http/Controllers/Api/IntegrationTransactionController.php`
Validated source snapshot and receipt writes

FINDINGS / PRIORITY 1-2

Security and workflow gaps

Review edition | 18 October 2026

A3 - High | Sandbox key can read production status

Reproduced: a sandbox key for the same merchant and branch successfully reads a transaction first accepted with a live key. Write and wallet endpoints enforce environment, but show() does not. This is an environment boundary issue; cross-tenant access remained denied.

Proposed: enforce environment on all data paths and persisted resource ownership. Until a truly isolated sandbox exists, sandbox credentials must not read live transactions. Add tests for same-tenant cross-environment reads.

A4 - High | Credential changes and audit are not atomic

Reproduced: forcing audit() to fail returns 500 after a key has already been inserted. A new active credential remains, while its one-time secret was not returned. Revoke similarly updates before its audit call (source review). Key creation also accepts an unregistered five-digit branch.

Proposed: wrap each lifecycle change plus audit in one transaction; validate an eligible registered branch; serialize creation policy checks. Never return a secret until its audited creation commits.

A5 - High | External capture is coupled to NUERS issuance

Observed: every new API event reserves the next NUERS authorized series number and creates an issued receipt. Even an active merchant with a valid key cannot ingest without the issuance gate. Existing ERP numbers and historical imports may conflict with the enforced prefix plus eight-digit format.

Proposed: distinguish an immutable copy of an already-issued external invoice from an invoice being issued by NUERS. Design the storage, evidence and numbering rules before exposing either mode. Keep existing gates until this review is approved; do not bypass authority controls.

Implementation evidence

`app/Http/Controllers/Api/IntegrationTransactionController.php`
authenticate(), show(), accept()
`app/Http/Controllers/Api/MerchantApiKeyController.php`
store(), destroy() and branch validation
`app/Services/InvoiceSequence.php`
One current series; strict next-number reservation

PROPOSED EXPERIENCE

VAT settings that match the seller

Review edition | 18 October 2026

A6 - Medium | Preview and selection need registration context

Current document selectors list all eight values, and the public preview infers seller VAT registration from the header tax_type. Add an explicit synthetic seller profile in preview, while production always uses the reviewed business profile.

Setting	Proposed behavior
Seller tax registration	Read-only VAT Registered / Non-VAT from Business Profile. A reviewed effective-date history preserves the classification used by each original.
Default line treatment	For VAT sellers: VATable 12%, VAT-Exempt, or Zero-Rated. For Non-VAT sellers: Non-VAT SSPT / exempt as legally applicable. This is a mapping default, not a tax-registration switch.
Per-product / line override	Keep tax category per line. Allow a product default, then evaluate customer, transaction, evidence and date. Require a maintained legal-basis reference for exempt/zero-rated use.
Mixed invoice	VAT seller: split VATable base, VAT, exempt and zero-rated totals. Non-VAT seller: retain Non-VAT invoice identity and separate SSPT/exempt totals.
Unsupported cases	Do not treat a generic discount_pct as a complete senior/PWD or other statutory workflow. Hold unsupported special-tax cases for a reviewed mapping.

Proposed validation order

Authenticate merchant / branch / environment → load reviewed seller registration → validate source schema and line categories → verify evidence and totals → resolve document family → apply relevant capture or issuance rules → atomically persist and debit once.

A7 - Medium | Guide is currently text-only

Replace both guide download actions with a versioned PDF and keep an accessible HTML companion. Publish only after this draft is reviewed. Include schema version, examples, known limits, change history and source links. The PDF supplied with this review is not yet installed on the live page.

DESIGN DECISION

Capture, issue and recover safely

Review edition | 18 October 2026

Mode proposed for review	Purpose	Required guardrails
External invoice capture	Store the original legal invoice already issued in the ERP/POS.	Preserve issuer/system, exact original number, date, tax snapshot and linkage. Do not reserve a second legal number or label a second original as issued. Verify source authority appropriate to that system.
NUERS invoice issuance	NUERS generates the legal original.	Maintain reviewed authority, branch, system scope and series. Reserve and issue atomically. Enforce wallet admission once.
Offline replacement / correction	Recover an authorized manual invoice, or correct an issued one.	Use a distinct linked document and workflow; retain the original. Define separate replacement and correction semantics, rather than modifying accepted JSON.

Why this requires review

The current contract represents finalized events, yet implements a new issuance. A mode change affects legal numbering, immutable source identity, fees, receipts, sales reports and BIR readiness. It must be designed with migrations and backward compatibility, rather than patched with an activation bypass.

Current BIR alignment checkpoint

RMC 98-2026 separates electronic invoicing from sales reporting; PTI and PTT have distinct triggers. Its downtime provision calls for authorized manual invoices and linked electronic replacements on restoration. It also specifies five mandatory certification tests, or seven with API callback. NUERS models seven accreditation stages as a different process; do not equate those stages with certification tests. Review each gate against the applicable authority [S5].

Recommended release boundary

Ship tax, environment and audit-atomicity fixes together with a reviewed capture/issuance contract. Keep callbacks and official BIR transmission visibly unavailable until their own verified implementations are ready. Do not present a funded wallet or active business as BIR authorization.

PROPOSED DELIVERY PLAN

Changes and acceptance criteria

Review edition | 18 October 2026

#	Change for review	Acceptance evidence required
1	Freeze contract and source semantics	Approve capture vs issuance, versioned tax fields, numbering, original-document links and fee policy. Existing version-1 accepted events retain replay compatibility.
2	Fix registration and tax buckets	VAT/Non-VAT matrix, all permitted mixed cases, tax-inclusive/exclusive totals, cents rounding, discounts, CWT and due amount. Reject invalid seller/document combinations.
3	Repair data and security boundaries	Buyer address and supported financial fields survive storage/render/export. Sandbox/live reads isolated. Create/edit/revoke audit failures roll back completely.
4	Add readiness and settings UI	Show registration, branch and authority status separately; document selection filtered; explicit synthetic preview profile; guide PDF downloadable from both actions.
5	Validate recovery and migration	Lost-response replay, key rotation, all-or-none batches, late failures, insufficient funds, linked replacements and original-source corrections. No replay double charge.
6	Staged and live release checks	Isolated MySQL concurrent duplicate/wallet tests; real approved connector and restart recovery; then read-only live verification and approved controlled transaction, if needed.

Database and deployment constraints

Use additive migrations and explicit schema versioning. Historical issued records and accepted request hashes must remain unchanged. Retain old replay decoding for accepted originals; prevent new invalid combinations. Do not introduce automatic tax-status changes, production test sales, account activation or webhook delivery as side effects of deployment.

Requested review

Review A1-A7 and the two integration modes. The companion guide describes today's API separately from the proposed additions. Approval of this design would authorize implementation planning; the current audit has not applied these changes.

EVIDENCE AND REFERENCES

Audit scope and official sources

Review edition | 18 October 2026

Local execution: 63 existing PHP regression tests / 654 assertions; 10 scratch audit tests / 34 assertions; 7 JavaScript outbox tests. The scratch tests include six observations of gaps and four control/calculation checks. First-run fixture issues were corrected before the final passing run. No security gap was fixed by making its observation test pass. Application source compared before and after the audit. Test fixtures use in-memory SQLite and notification dispatch disabled. This is not a penetration test, a load certification, a tax opinion for a particular product, or a certification of the live merchant account.

[S1] RR 7-2024, Section 6(B), pp. 12-14
Open official source
[S2] RMC 77-2024, Q25 and Q28, pp. 9-10
Open official source
[S3] RMC 77-2024, official samples A1-A2 / B1-B6
Open official source
[S4] RR 6-2026, Sections 2, 3 and 6
Open official source
[S5] RMC 98-2026, IV.2, IV.11-15
Open official source
[S6] RA 10963, amendments to Sections 106 and 108
Open official source
[S7] RMC 66-2025, qualified RBE zero-rating evidence
Open official source
[S8] BIR advisory, 11 June 2025, EOE/RBE zero-rating
Open official source

Source interpretation

The proposed model is an engineering interpretation of the cited rules and current source, not a BIR-approved API schema. Ordinary 12% arithmetic is covered here; product-specific exemptions, zero-rating evidence, special incentives and effective dates require maintained transaction-specific rules. The June 2025 advisory and RMC 66-2025 are relevant qualification sources, not a basis for blanket zero-rating.

Reviewed local documentation: docs/integrations/merchant-ingestion-1.md; docs/NUERS_TRANSACTION_API_INTEGRATION.md; docs/knowledge/permits-integrations-and-sessions.md. The guide and legacy wording must be revised together once the model is approved.